Análise e decisões técnicas — Brindes Sicoob V2

7 de outubro de 2026 · Base revisada: `a974d77326217b237bbffec0aa01770efbf3e64a` · Sistema em construção.

Decisão central: preservar a arquitetura existente e fechar a jornada de compra com contrato de catálogo validado, banco reconciliado, documentos operacionais e esteira de publicação confiável. O código do GitHub não deve substituir automaticamente as correções já implantadas.

Esta rodada executou análise, consultas de leitura e simulações isoladas. Não alterou schema/dados remotos, não publicou funções e não fez merge de PRs. As decisões abaixo são propostas escolhidas pelo responsável técnico, não correções já concluídas.

Achados que orientam as escolhas

`P1 · F01`

Contrato do catálogo incompatível com código

A tabela de produtos possui is_active e não possui active, base_price ou image_url. A seleção atual de external-db-bridge no GitHub retorna HTTP 400; a seleção implantada retorna 200. As seleções de kits e recompra retornam 400 mesmo nas versões implantadas. A confirmação foi uma leitura dos mesmos campos pela Data API; não foi uma compra ou execução completa dessas Edge Functions.

Evidência

`P1 · F02`

Scanner documental sem configuração

Os nomes SICOOB_MALWARE_SCANNER_URL e SICOOB_MALWARE_SCANNER_TOKEN estão ausentes da lista de secrets. O handler exige ambos e falha fechado quando ausentes. Upload operacional e homologação EICAR continuam pendentes.

Evidência

P1 · F03

Dois crons falhando no banco real

archive-old-admin-audit-logs referencia admin_audit_log_archive, removida pela migration de 16/09. trim-connection-test-history chama uma função RETURNS trigger diretamente. O trigger correto está habilitado e mantém a limpeza por conexão.

Evidência

P1 · F04

Dependências bloqueiam CI

npm audit reportou 14 alertas por pacote: 7 altos e 7 moderados. A cadeia braces inclui Tailwind 3 e md-to-pdf; braces 3.0.3 não possui versão corrigida publicada. source-map-js tem correção em 1.2.2.

Evidência

P1 · F05

Critérios de integração insuficientes

A proteção da main não exige status checks e não é imposta a administradores. O PR 97 falhou no gate de dependências e no upload CodeQL, pois code scanning não está habilitado. O E2E do PR 94 falhou esperando a tela Tendências.

Evidência

P1 · F06

Testes de RLS aceitam resultados sem comprovação

tests/rls/e2e-cleanup-rate-limit.test.ts contém expect(error || true).toBeTruthy() em UPDATE e DELETE: essas asserções sempre passam. Alguns contratos remotos são ativados apenas pela presença de variáveis e confundem indisponibilidade com negação válida.

Evidência

P2 · F07

Dívida de qualidade medida

O baseline TypeScript passou com 153 diagnósticos, não com zero erros. ESLint encontrou 3247 erros e 2746 avisos. O build passou.

Evidência

P2 · F08

Reconciliação de schema e histórico pendente

As migrations 20260928140600 e 20261002160000 não estão no ledger. A primeira torna explícito o bloqueio já implícito em nove tabelas; a segunda melhora os erros de IDs inválidos. Os tipos gerados estão defasados, conforme auditoria anterior. Lista vazia de statements no ledger não comprova divergência de SQL.

Evidência

P2 · F09

Descoberta dos produtos distante da entrada

Na demonstração de loja, o primeiro card começa em y=1599 px no desktop de 1440 px e y=1744 px no mobile de 390 px. Isso fundamenta reduzir a área introdutória e aproximar busca e produtos. As métricas são da demonstração, não de uma sessão autenticada.

Evidência

P2 · F10

Funcionalidades de encerramento ainda incompletas

Permanecem lacunas em capacidade física de embalagem, importação assistida de destinos, propostas institucionais/fornecedor único, cronograma regressivo de campanha e interfaces para colaboração Magic Up/views de auditoria. As buscas atuais e a revisão de 01/10 sustentam a priorização; o plano completo não foi certificado linha a linha nesta rodada.

Evidência

P2 · F11

Conectividade não equivale a operação concluída

O último teste registrado do catálogo estava positivo; o do CRM estava em erro desde 06/10. Na outbox houve 1437 despachos com 200, um timeout e um 503 nas últimas 24h; não havia linhas de entrega para certificar comunicação com compradores.

Evidência

P2 · F12

Carga de módulos merece otimização dirigida

O build gerou lucide-react com aproximadamente 768 kB minificados; há oito imports de namespace no módulo de kits. Voz e XLSX também geram chunks grandes. Tamanho do chunk não prova transferência inicial: medir por rota antes de intervir.

Evidência

Verificações desta rodada

Verificação	Resultado	Limite
Vitest local	5611 aprovados; 0 falhas; 112 ignorados	Contratos remotos ignorados não comprovam operação. A primeira rodada usou env sintético inadequado para os contratos remotos; foi corrigida e reexecutada.
Cenários Node	213 aprovados	Contratos locais, não homologação completa do banco.
PostgreSQL descartável	Governança, identidade e migration candidata aprovadas	Fixtures em contêiner isolado; o banco real recebeu somente consultas.
Build	Aprovado	Variáveis sintéticas; não é artefato para publicação.
TypeScript	153 diagnósticos; baseline aprovado	Aprovação do baseline impede regressão; não significa tipos sem erros.
ESLint	3247 erros; 2746 avisos	Dívida global; sem alteração da baseline.

Dependências	14 alertas por pacote; 7 altos	Inclui efeitos transitivos da mesma vulnerabilidade.
Navegador e axe	9 combinações passaram	Login sintético e demonstração em 320/390/1440 px; revisão humana e sessão real pendentes.
Catálogo real	Contrato mínimo 200; campos inexistentes 400	GETs com limite de uma linha, sem expor produto ou credencial no relatório.
Banco canônico	Views com security_invoker; nenhuma constraint pública NOT VALID	Não substitui matriz de personas RLS e jornada real.

Resumo estruturado

Opções escolhidas

D01 · Planejamento · T001–T010

Adotar o plano de encerramento de 01/10 como referência única

Manter IDs T001–T100 e suas origens; atualizar estado e prova por entrega. Evita perder requisitos entre planos concorrentes.

Aceite: Estado de cada entrega ligado a SHA, teste e destino.

D02 · Arquitetura · T010/T023

Preservar React, TypeScript, Vite e Supabase

Evoluir os módulos existentes. A análise não mostrou motivo para reconstruir o portal nem introduzir outro backend.

Aceite: Fluxos mantidos com regressão testada.

D03 · Repositório · T001/T002

Usar o main remoto em worktree e reconciliar mudanças locais individualmente

O checkout original está 64 commits atrás e tem alterações do usuário. Incorporar apenas diferenças reais; preservá-las antes de qualquer atualização.

Aceite: Nenhuma edição perdida; candidato com SHA conhecido.

D04 · Catálogo · T058/T059

Normalizar o contrato no bridge usando os campos reais

Selecionar is_active, sale_price e primary_image_url; aliases necessários ao domínio ficam no adaptador. Não criar campos artificiais nem escrever no catálogo mestre para satisfazer o frontend.

Aceite: As seleções reais de catálogo, kit e recompra retornam 200 e validam tipo, mínimo, saldo e preço.

D05 · Paridade Edge · T030/T039/T070

Incorporar a correção implantada de active/is_active e corrigir base_price/image_url nas duas origens

O código implantado contém um ajuste válido ausente do GitHub, mas kits e recompra ainda têm consultas inválidas. Publicar só depois de testar o contrato.

Aceite: Fonte e implantação coincidem no candidato e consultas reais passam.

D06 · Banco · T021–T030

Aplicar apenas migrations revisadas e faltantes, com hash e transação

A candidata 20261002160000 passou na simulação adicional. Incluir a política explícita de tabelas internas no aplicador autorizado; não executar o backlog histórico em massa.

Aceite: Ledger, definição viva e testes do lote correspondem.

D07 · Auditoria do banco · T026/T076/T089

Retirar o cron de arquivamento obsoleto e planejar retenção compatível com partições

A tabela de destino foi removida intencionalmente. Preservar dados; a política de retenção existente não autoriza descarte improvisado para esconder o erro.

Aceite: Sem agendamento inválido; eventual arquivamento preserva integridade, permissões e retenção aprovada.

D08 · Limpeza do banco · T026

Remover o cron redundante de trim e conservar o trigger válido

A função usa NEW.connection_id e mantém 200 registros por conexão; o trigger está habilitado. A rotina diária é inválida e duplicada.

Aceite: Inserções acima do limite continuam retendo os registros corretos; cron não volta a chamar trigger diretamente.

D09 · Tipos · T023

Regenerar tipos do banco após reconciliar o lote

Corrigir consumidores conforme contratos verdadeiros; usar versões fixadas do gerador e comparação automatizada.

Aceite: Tipos compilam e nenhuma edição manual mascara objeto ausente.

D10 · Autenticação · T024/T025/T030

Versionar a política de autenticação por Edge Function

Distinguir usuário, worker interno e webhook público assinado. Preservar os validadores existentes e alinhar verify_jwt ao contrato; ativação global pode quebrar chamadas internas.

Aceite: Sem token, token inválido, papel insuficiente e outra cooperativa são negados; chamador permitido funciona.

D11 · Documentos · T074–T080

Usar ClamAV privado com adaptador HTTP para o contrato existente

Manter quarentena privada, atualização de assinaturas, hash, timeout e bloqueio sem parecer. Dimensionar o host e testar a integração antes da liberação.

Aceite: Arquivo limpo liberado; EICAR, indisponibilidade e parecer inválido bloqueados; download respeita escopo.

D12 · Dependências · T011–T020/T092/T093

Atualizar source-map-js, substituir md-to-pdf por impressão com Playwright e migrar Tailwind 4 em lote próprio

Apenas Tailwind e md-to-pdf introduzem braces na árvore atual. Não existe patch upstream de braces para um override simples. A migração visual exige prova de compatibilidade e novo audit, sem npm audit fix --force.

Aceite: Cadeias vulneráveis removidas; audit e regressão visual passam no lockfile final.

D13 · CI · T011–T020

Exigir checks concretos e impedir aprovação com teste ausente

Obrigar qualidade, contratos/RLS e smoke autenticado do SHA. Credencial ausente bloqueia o gate de integração. Não tratar todo continue-on-error como defeito: alguns têm gate de falha posterior.

Aceite: Falha real ou ausência de execução bloqueia merge e publicação.

D14 · Segurança de código · T011–T020

Preservar análise estática e corrigir a integração CodeQL

Confirmar habilitação/licença do repositório privado antes de escolher upload SARIF. Não assumir que mudar runner corrige configuração do serviço. Manter análise local/artefatos e gates já existentes.

Aceite: Ferramenta executa, artefato é revisável e resultado não é marcado verde por upload omitido.

D15 · Testes · T014/T024/T095/T096

Separar suíte local, integração remota e E2E por configuração explícita

Substituir asserções tautológicas por estado antes/depois e expectativa de erro precisa. A primeira rodada com endpoint sintético habilitou contratos remotos por presença de env; a rodada local corrigida passou.

Aceite: Servidor indisponível não é aceito como prova de RLS; skips e origem dos testes ficam explícitos.

D16 · Qualidade · T010–T020

Reduzir dívida de tipos e lint por fluxo crítico sem ampliar baseline

Começar por catálogo, orçamento, autorização e financeiro. Corrigir a causa após gerar tipos; evitar refatoração global de milhares de linhas sem ligação com entrega.

Aceite: Cada lote reduz dívida e não introduz novos diagnósticos.

D17 · Compra · T031–T040/T051–T070

Adotar jornada B2B de orçamento e aprovação

Fluxo: produto → quantidade/personalização → revisão → aprovação → pedido → arte → produção → entrega. Revalidar preço, mínimo, saldo e verba no servidor; consulta de estoque não promete reserva.

Aceite: Retry, mudança de preço, duas abas e concorrência preservam intenção, identidade e totais.

D18 · Governança · T052–T057

Políticas versionadas e configuráveis por cooperativa

Quantidade de propostas, alçadas e exceção de fornecedor único são configuráveis; exigir justificativa e responsável. Não inventar obrigação universal de três propostas ou limites financeiros.

Aceite: Alteração material invalida aprovação quando previsto; outra cooperativa não decide nem lê o pedido.

D19 · Comunicação · T046–T050

Manter outbox transacional existente e medir entrega efetiva

Reconciliar timeout/503 com deduplicação e tentativa auditada. Sucesso do cron/HTTP sem mensagens não comprova notificação ao comprador.

Aceite: Uma intenção gera uma entrega confirmada ou uma falha acionável, sem duplicação.

D20 · Kits · T062–T066

Exigir especificação física ou revisão técnica registrada

Preço e estoque corretos não comprovam que o conjunto cabe na embalagem. Usar dimensões, peso e tolerâncias; dado ausente bloqueia confirmação física automática.

Aceite: Kit incompatível é recusado; exceção técnica é identificada, versionada e auditável.

D21 · Logística e financeiro · T081–T090

Concluir distribuição com importação validada e saldos por destino

Prévia de CSV/XLSX, erros por linha, confirmação atômica, recebimento parcial, avaria, devolução e compensação financeira ligados ao pedido.

Aceite: Três destinos reconciliam quantidades e valores sem duplicar lançamento.

D22 · Experiência · T060/T071/T092

Aproveitar a identidade da vitrine e separar compra da gestão

Manter fotos reais de SKU, busca dominante, navegação por finalidade e orçamento persistente. Levar o padrão de loja à jornada autenticada; a demonstração continua identificada como fictícia.

Aceite: Comprador monta orçamento sem atravessar menus técnicos; gestores acessam a área própria.

D23 · Conversão · T060/T092

Reduzir a introdução e antecipar produtos na primeira visita

O primeiro card da demo começa após 1599/1744 px. Compactar hero/faixas; priorizar busca e cards, com recompra/histórico nas visitas seguintes. Curadoria por finalidade usa atributos verificados.

Aceite: Produtos aparecem mais cedo e o usuário mantém contexto de busca, filtros e orçamento em mobile.

D24 · Desempenho · T094

Otimizar por rota e substituir catálogo completo de ícones por mapa explícito

Carregar voz, BI e planilhas quando utilizados. Medir JS transferido e experiência nas rotas principais, não só o maior arquivo do build.

Aceite: Orçamentos de tamanho/tempo definidos e medidos no candidato, sem aumentar limites para ocultar regressão.

D25 · Escopo · T078/T086/T089/T096

Priorizar compra completa; executar módulos avançados depois com pendência explícita

Magic Up colaborativo, BI avançado e voz permanecem no plano. Implementar as lacunas após estabilizar orçamento, arte, documento e entrega; não contar tabelas vazias como funcionalidade entregue.

Aceite: Cada módulo tem UI, autorização, testes e destino integrado antes do aceite.

D26 · Conclusão · T095–T100

Encerrar por evidência de jornada e piloto autorizado

Dados sintéticos de duas cooperativas e três destinos; testes positivos, adversariais, concorrência e falhas. Operação real e 30 dias de estabilidade são etapas futuras, não simuláveis como aceite.

Aceite: Candidato publicado reproduz o SHA testado; compra/entrega e estabilidade têm prova observada.

Sequência de execução escolhida

1. Fixar candidato, preservar mudanças locais e corrigir o contrato do catálogo; importar o ajuste válido já implantado.
2. Resolver dependências e gates do CI em lotes próprios; vincular checks confiáveis à proteção da branch.
3. Reconciliar migrations, retirar agendamentos inválidos, gerar tipos e validar autenticação/configuração das funções.
4. Homologar orçamento, aprovação, verba, arte, scanner, expedição e financeiro com duas cooperativas e três destinos.
5. Concluir lacunas institucionais, embalagem, importação e campanhas. Evoluir a vitrine e os ajustes de desempenho em paralelo, integrando-os ao candidato validado.
6. Executar regressão conectada, reconciliar publicação e seguir para piloto autorizado e estabilidade observada.

Plano existente de 100 etapas · Decisões estruturadas

Limites e fontes

A consulta administrativa direta ao projeto de catálogo não foi autorizada para o token CLI. O contrato foi validado depois pela Data API com a conexão já cadastrada no banco canônico, mantida apenas em memória. Nenhuma credencial foi salva neste relatório. A jornada autenticada integral, o scanner real e o piloto permanecem sem validação nesta rodada.

O inventário de paridade de 101 migrations, tipos e 100 funções vem da auditoria anterior nesta sessão; as consultas atuais revalidaram migrations recentes, rotinas e os contratos indicados. Não foi atribuído percentual de conclusão nem nota 10/10.

- Supabase: autenticação e verify_jwt
- Supabase: migrations
- Aviso de segurança braces: sem patch publicado

- Aviso de segurança source-map-js: versão corrigida 1.2.2
- ClamAV: implantação privada e recursos necessários

Captura da vitrine demonstrativa desktop · Captura mobile · Teste de login · Teste demonstrativo